# Strong authentication and privileged access — Keycloak

Menhir Finance (fictive) · Keycloak — royaume menhir (fournisseur d'identité)

Prepared by: **Attest (AI-assisted)**
Date: **2026-11-11 12:30**

Auditor sign-off: **pending**
Run: **20261111-121909-keycloak-bench-meta**

Owner: **IT department — IAM team**

## 1. Executive summary

OPINION AT TESTING

**Unsatisfactory**

**Basis for opinion**

7 controls tested (7 conclusive) against: DORA Art. 9(4) · RTS (EU) 2024/1774 Art. 12, 21 · PSI-4. Tests run on 2026-11-11 12:30, environment: Test Keycloak (fictitious realm). The opinion rests solely on the verdicts of the deterministic test scripts and on the evidence sealed in the audit trail.

**Scope limitation:** Work programme and test scripts drafted by AI and not yet reviewed by an auditor; requirements needing document review or interview are not covered; the opinion applies at the test date only.

| | | | |
|---|---|---|---|
| **7** controls tested | **4** findings | **0** findings closed and verified | **4** open findings |
| **0** human approvals | **88** sensitive data items masked in evidence | **1 min 06 s** audit duration | **$0.085 *** measured AI cost |

Critical: 1 · High: 1 · Medium: 2 · Low: 0

### Key messages

- 4 findings across 7 controls: 1 critical, 1 high, 2 medium.
- 4 findings remain open, with an action plan, an owner and a due date.

## 2. Scope and method

| | |
|---|---|
| Engagement | AUD-2026-KC-01 |
| Entity | Menhir Finance (fictive) |
| System | Keycloak — royaume menhir (fournisseur d'identité) |
| System criticality | Supports critical or important functions (DORA) |
| Environment | Test Keycloak (fictitious realm) |
| Owner | IT department — IAM team |
| Lead auditor | Attest CI (automated run, no human auditor) |
| Date | 2026-11-11 12:30 |
| Framework | DORA Art. 9(4) · RTS (EU) 2024/1774 Art. 12, 21 · PSI-4 |

| | |
|---|---|
| Audited target | Keycloak (open-source identity provider), through the read-only gateway |
| Work programme | existing catalogue reused · controls/AUD-2026-KC-01.en.json |

### In scope

- Security settings of the Keycloak realm (password, lockout, session, logging)
- Realm accounts and members of the admin role

### Out of scope

- Intrinsic strength of MFA factors and custom authentication flows
- Clients, identity federation and connected applications
- Hosting and operation of the Keycloak server

### Method

1. Controls are derived from the framework (DORA, RTS 2024/1774, internal policy); severity is the one set by the policy.
2. Each test is a stored Python script, statically checked before execution (read-only) and run with a read-only service account.
3. The verdict comes from the script, never from the model. A screenshot is reviewed by Muse Spark to corroborate; on disagreement the control is flagged for review.
4. SAM 3.1 delineates the proving rows and the personal data, which is masked before distribution.
5. No remediation was applied during this engagement: each finding is handed to the system owner for an action plan, and closing it will require a new test once the gap has been addressed.
6. Every event and piece of evidence is sealed in a hash-chained audit trail (SHA-256).

### Limitations

- Tests cover the configuration reported by the system, not the actual strength of authentication factors.
- Point-in-time test: the configuration was observed on 2026-11-11; the tests assess the design and implementation of the controls at that date, not their operating effectiveness over a period.
- AI-drafted scripts and catalogue must be reviewed by an auditor before being considered validated.
- Fictitious entity and data: demonstration.

## 3. Findings overview

| REF. | RULE | TITLE | SEVERITY | TESTED | STATUS | DUE DATE |
|---|---|---|---|---|---|---|
| F-01 | PSI-4.1 | MFA enforced for privileged administrator accounts | Critical | Non-compliant | Open | 2026-12-11 |
| F-02 | PSI-4.2 | MFA enforced for users of critical system | High | Non-compliant | Open | 2027-02-09 |
| F-03 | PSI-4.3 | Minimum password length and complexity | Medium | Non-compliant | Open | 2027-05-10 |
| F-04 | PSI-4.5 | Inactive session timeout | Medium | Non-compliant | Open | 2027-05-10 |
| – | PSI-4.4 | Account lockout after repeated failures | Medium | Compliant | | |
| – | PSI-4.6 | Logging of administration actions | High | Compliant | | |
| – | PSI-4.7 | No generic or shared administrator accounts | High | Compliant | | |

## 4. Detailed findings and controls

### F-01 PSI-4.1 MFA enforced for privileged administrator accounts

Critical · Non-compliant · Open

**CRITERIA**

Every account holding the realm role admin must have multi-factor authentication configured.

PSI-4.1 · DORA 9(4)(d), RTS 21(1)(f)(ii)

**CONDITION**

Observed: `["y.tanguy"]`

Expected: `totp=true for all users with role admin`

Checked 4 admin users: 1 without MFA.

**PROBABLE CAUSE**

MFA enrollment for administrators was not enforced at provisioning due to missing configuration or control. (AI hypothesis, not tested: to be confirmed with the owner)

**RISK**

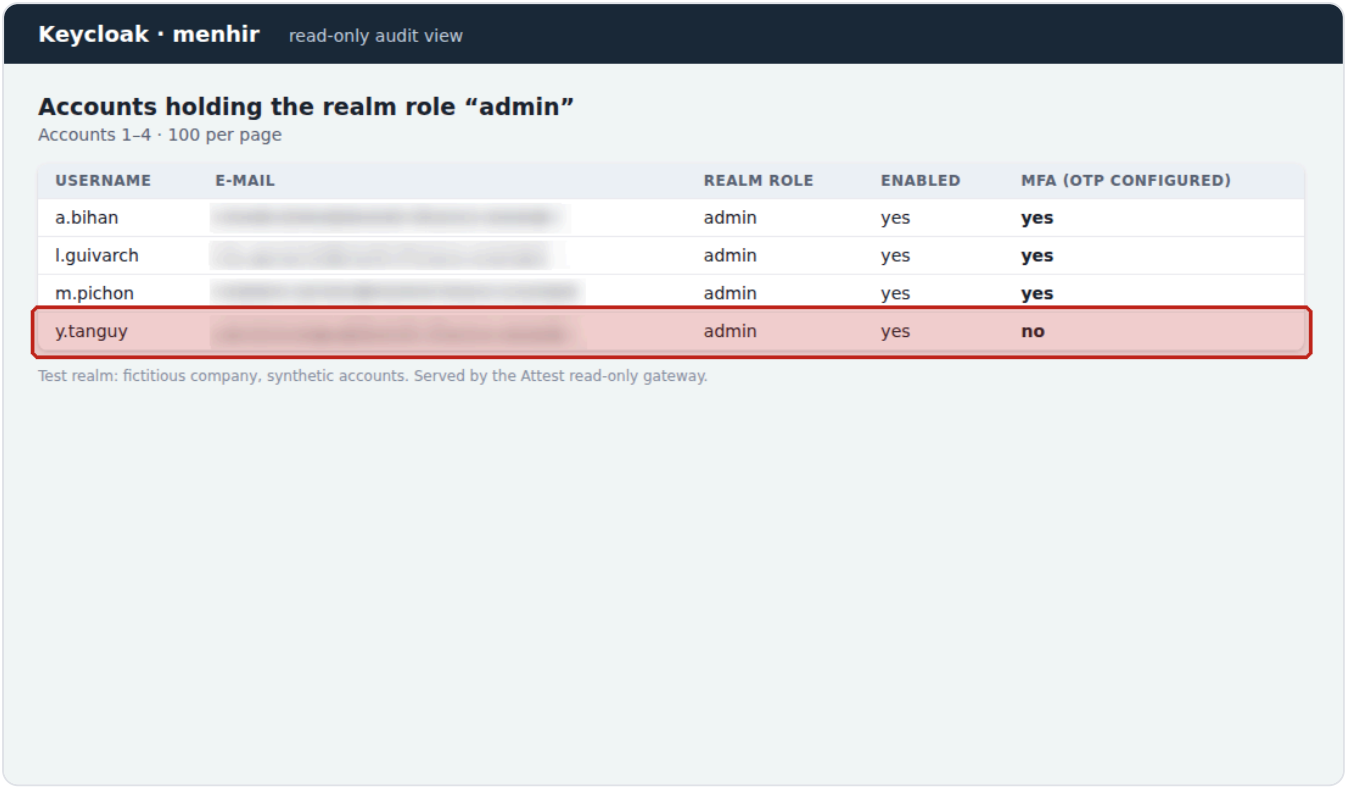
Compromise of a password-only administrator account would allow full takeover of the identity provider.

**RECOMMENDATION**

Enforce OTP enrollment for all admin accounts and remove privileged access until MFA is configured.

Due date: 2026-12-11 · Owner: IT department — IAM team

Test procedure: Retrieve all members of the realm role admin via GET /api/kc/roles/admin/users and verify totp is true for each account.




**At testing** — The screenshot corroborates the test. Screenshot shows y.tanguy holding admin role with MFA marked no, matching the failed test. · 4/4 sensitive data items masked

`2026-11-11 12:30:42 · SHA-256 f7b6246495be5129…`

### F-02 PSI-4.2 MFA enforced for users of critical system

High · Non-compliant · Open

**CRITERIA**

Every user account in the Keycloak realm, which supports critical or important functions, must have multi-factor authentication configured.

PSI-4.2 · DORA 9(4)(d), RTS 21(1)(f)(ii)

**CONDITION**

Observed: `["y.tanguy"]`

Expected: `totp=true for all users`

Checked 180 users, 1 without MFA.

**PROBABLE CAUSE**

MFA was not made mandatory by default for all users due to incomplete authentication flow configuration. (AI hypothesis, not tested: to be confirmed with the owner)

**RISK**

Password-only authentication exposes critical-function accounts to phishing and credential theft.

**RECOMMENDATION**

Require OTP enrollment for all realm users and disable accounts that have not enrolled.

Due date: 2027-02-09 · Owner: IT department — IAM team

Test procedure: Retrieve all user accounts via GET /api/kc/users with pagination and verify totp is true for each account.

**Keycloak · menhir** read-only audit view

## User accounts

Accounts 101–180 · 100 per page ← previous page

| USERNAME | E-MAIL | REALM ROLE | ENABLED | MFA (OTP CONFIGURED) |
|---|---|---|---|---|
| l.uguen | [redacted] | — | yes | **yes** |
| m.allain | [redacted] | — | yes | **yes** |
| m.briand | [redacted] | — | yes | **yes** |
| m.dubois | [redacted] | — | yes | **yes** |
| m.dupont | [redacted] | — | yes | **yes** |
| m.floch | [redacted] | — | yes | **yes** |
| m.garcia | [redacted] | — | yes | **yes** |
| m.gourmelen | [redacted] | — | yes | **yes** |
| m.guillou | [redacted] | — | yes | **yes** |
| m.hamon | [redacted] | — | yes | **yes** |
| m.jaouen | [redacted] | — | yes | **yes** |
| m.jaouen2 | [redacted] | — | yes | **yes** |
| m.jegou | [redacted] | — | yes | **yes** |
| m.jegou2 | [redacted] | — | yes | **yes** |
| m.kervella | [redacted] | — | yes | **yes** |
| m.lefloch | [redacted] | — | yes | **yes** |
| m.pichon | [redacted] | admin | yes | **yes** |
| m.quillien | [redacted] | — | yes | **yes** |
| n.abgrall | [redacted] | — | yes | **yes** |
| n.bonnet | [redacted] | — | yes | **yes** |
| n.dupont | [redacted] | — | yes | **yes** |
| n.gourmelen | [redacted] | — | yes | **yes** |
| n.hamon | [redacted] | — | yes | **yes** |
| n.hamon2 | [redacted] | — | yes | **yes** |
| n.lambert | [redacted] | — | yes | **yes** |
| n.prigent | [redacted] | — | yes | **yes** |
| n.raoul | [redacted] | — | yes | **yes** |
| n.tanguy | [redacted] | — | yes | **yes** |
| n.vincent | [redacted] | — | yes | **yes** |
| o.tanguy | [redacted] | — | yes | **yes** |
| p.bertrand | [redacted] | — | yes | **yes** |
| p.david | [redacted] | — | yes | **yes** |
| p.gourmelen | [redacted] | — | yes | **yes** |
| p.henaff | [redacted] | — | yes | **yes** |
| p.henaff2 | [redacted] | — | yes | **yes** |
| p.jaouen | [redacted] | — | yes | **yes** |
| p.le-roux | [redacted] | — | yes | **yes** |
| p.martin | [redacted] | — | yes | **yes** |
| p.morvan | [redacted] | — | yes | **yes** |
| p.petit | [redacted] | — | yes | **yes** |
| p.quere | [redacted] | — | yes | **yes** |
| q.girard | [redacted] | — | yes | **yes** |
| q.kerbrat | [redacted] | — | yes | **yes** |
| q.kervella | [redacted] | — | yes | **yes** |
| q.kervella2 | [redacted] | — | yes | **yes** |
| q.vigouroux | [redacted] | — | yes | **yes** |
| q.vigouroux2 | [redacted] | — | yes | **yes** |
| r.fournier | [redacted] | — | yes | **yes** |
| r.girard | [redacted] | — | yes | **yes** |

| | | | | |
|---|---|---|---|---|
| r.girard | [redacted] | — | yes | **yes** |
| r.gourvennec | [redacted] | — | yes | **yes** |
| r.hamon | [redacted] | — | yes | **yes** |
| r.lambert | [redacted] | — | yes | **yes** |
| r.michel | [redacted] | — | yes | **yes** |
| s.cloarec | [redacted] | — | yes | **yes** |
| s.floch | [redacted] | — | yes | **yes** |
| s.kerjean | [redacted] | — | yes | **yes** |
| s.le-goff | [redacted] | — | yes | **yes** |
| s.le-meur | [redacted] | — | yes | **yes** |
| s.morvan | [redacted] | — | yes | **yes** |
| s.richard | [redacted] | — | yes | **yes** |
| s.tanguy | [redacted] | — | yes | **yes** |
| s.uguen | [redacted] | — | yes | **yes** |
| t.briand | [redacted] | — | yes | **yes** |
| t.gourmelen | [redacted] | — | yes | **yes** |
| t.kerbrat | [redacted] | — | yes | **yes** |
| t.le-goff | [redacted] | — | yes | **yes** |
| u.le-roux | [redacted] | — | yes | **yes** |
| u.le-roux2 | [redacted] | — | yes | **yes** |
| u.nedelec | [redacted] | — | yes | **yes** |
| u.tanguy | [redacted] | — | yes | **yes** |
| v.bertrand | [redacted] | — | yes | **yes** |
| v.garcia | [redacted] | — | yes | **yes** |
| x.gourmelen | [redacted] | — | yes | **yes** |
| x.le-bihan | [redacted] | — | yes | **yes** |
| x.le-gall | [redacted] | — | yes | **yes** |
| y.even | [redacted] | — | yes | **yes** |
| y.laurent | [redacted] | — | yes | **yes** |
| y.tanguy | [redacted] | admin | yes | **no** |
| y.vincent | [redacted] | — | yes | **yes** |
| z.lefloch | [redacted] | — | yes | **yes** |

Test realm: fictitious company, synthetic accounts. Served by the Attest read-only gateway.

**At testing** — The screenshot corroborates the test. Screenshot shows accounts 101-180 with y.tanguy as the only account with MFA marked no. · 80/80 sensitive data items masked (78 spotted by the AI, the rest by the deterministic safety net)
`2026-11-11 12:31:27 · SHA-256 dad7faedc4d194d7…`

### F-03 PSI-4.3 Minimum password length and complexity

Medium · Non-compliant · Open

**CRITERIA**

Password policy must require at least 12 characters with complexity requirements.
PSI-4.3 · DORA 9(4)(d)

**CONDITION**

Observed: `length(14)`
Expected: `passwordPolicy contains length(12) and upperCase, lowerCase, digits, specialChars`
Checked 1 realm representation and passwordPolicy does not require length 12 with upperCase, lowerCase, digits and specialChars.

**PROBABLE CAUSE**

Secure password policy defaults were not applied when the realm was configured. (AI hypothesis, not tested: to be confirmed with the owner)

**RISK**

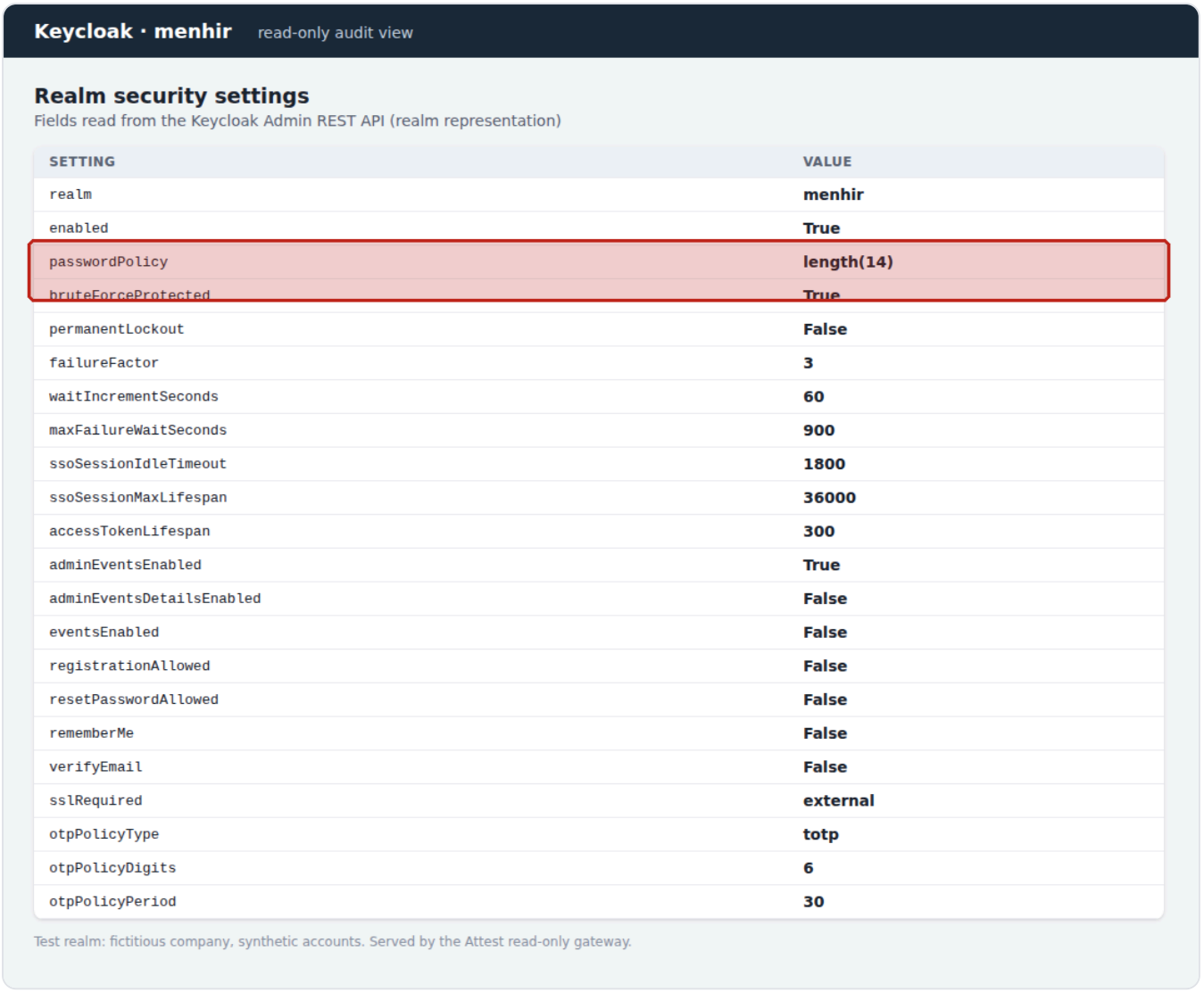
Weak passwords can be brute-forced or guessed, leading to unauthorized access.

**RECOMMENDATION**

Set the realm password policy to at least 12 characters with upper/lower case, digits and special characters.

Due date: 2027-05-10 · Owner: IT department — IAM team

Test procedure: Retrieve the realm representation via GET /api/kc/realm and verify the passwordPolicy requires length 12 and complexity.




**At testing** — The screenshot corroborates the test. Screenshot shows passwordPolicy is length(14) with no complexity requirements.

`2026-11-11 12:30:37 · SHA-256 64b8789ad5b89ccb…`

## F-04 PSI-4.5 Inactive session timeout

Medium · Non-compliant · Open

**CRITERIA**

Idle sessions must expire after at most 15 minutes and idle timeout must never be disabled.

PSI-4.5 · DORA 9(4)(c)

**CONDITION**

Observed: `1800`

Expected: `ssoSessionIdleTimeout<=900 and >0`

ssoSessionIdleTimeout is 1800 seconds, exceeding 15 minutes.

**PROBABLE CAUSE**

Session timeout was left at the insecure default value due to missing hardening baseline. (AI hypothesis, not tested: to be confirmed with the owner)

**RISK**

Overly long idle sessions allow session hijacking from unattended workstations.

**RECOMMENDATION**

Set the SSO idle session timeout to 15 minutes or less.

Due date: 2027-05-10 · Owner: IT department — IAM team

Test procedure: Retrieve the realm representation via GET /api/kc/realm and verify ssoSessionIdleTimeout is set to 900 seconds or less.

**Keycloak · menhir** read-only audit view

### Realm security settings

Fields read from the Keycloak Admin REST API (realm representation)

| SETTING | VALUE |
|---|---|
| realm | **menhir** |
| enabled | **True** |
| passwordPolicy | **length(14)** |
| bruteForceProtected | **True** |
| permanentLockout | **False** |
| failureFactor | **3** |
| waitIncrementSeconds | **60** |
| maxFailureWaitSeconds | **900** |
| ssoSessionIdleTimeout | **1800** |
| ssoSessionMaxLifespan | **36000** |
| accessTokenLifespan | **300** |
| adminEventsEnabled | **True** |
| adminEventsDetailsEnabled | **False** |
| eventsEnabled | **False** |
| registrationAllowed | **False** |
| resetPasswordAllowed | **False** |
| rememberMe | **False** |
| verifyEmail | **False** |
| sslRequired | **external** |
| otpPolicyType | **totp** |
| otpPolicyDigits | **6** |
| otpPolicyPeriod | **30** |

Test realm: fictitious company, synthetic accounts. Served by the Attest read-only gateway.

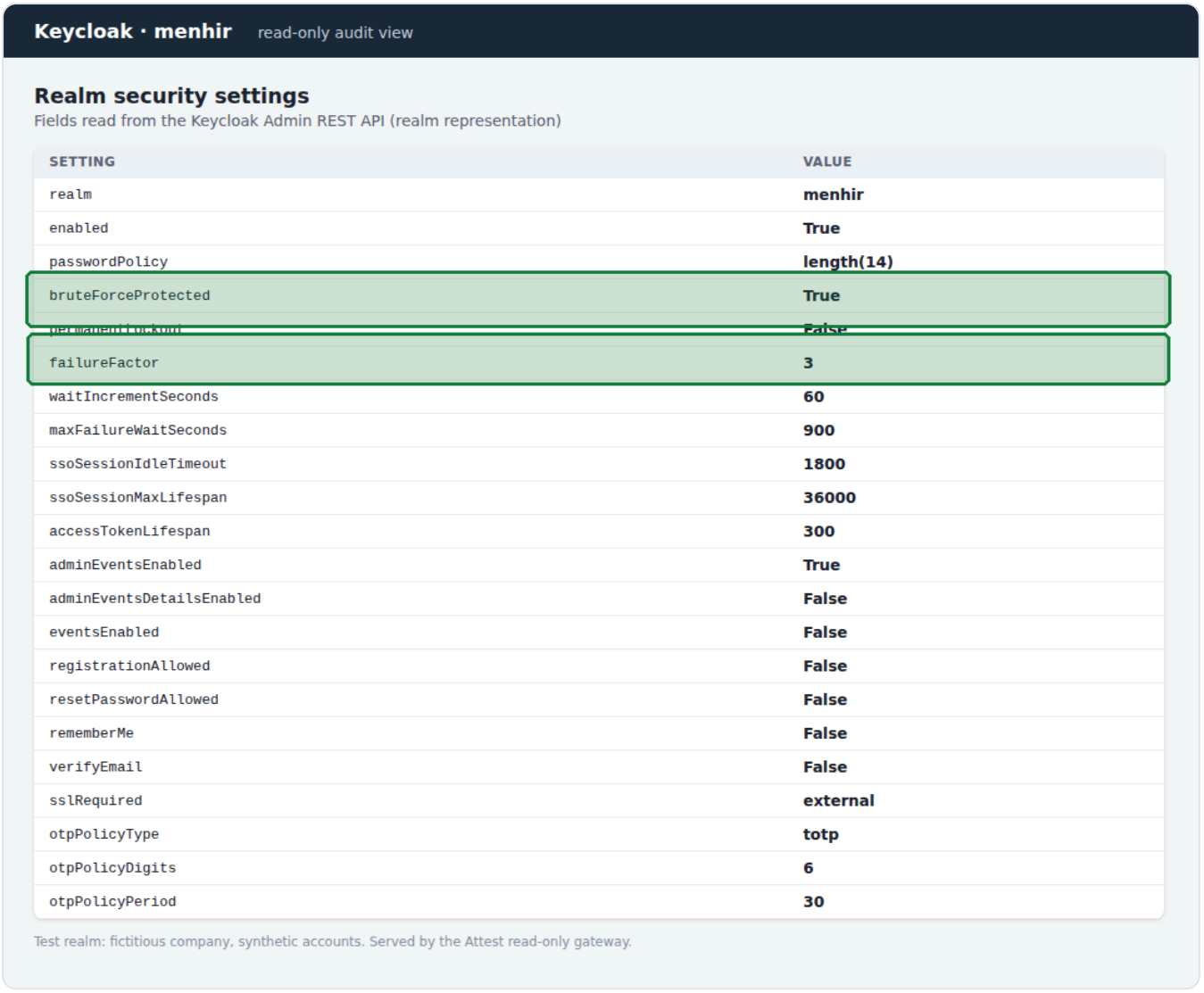
**At testing** — The screenshot corroborates the test. The screenshot shows ssoSessionIdleTimeout is 1800 seconds, exceeding the 900-second limit.

`2026-11-11 12:30:51 · SHA-256 b0a6437a5f151779…`

## PSI-4.4 Account lockout after repeated failures

Medium · Compliant

Compliant control — Account lockout must be enabled and trigger after at most 5 failed logins, never disabled. · DORA 9(4)(c)
Observed: `{"bruteForceProtected": true, "failureFactor": 3}`

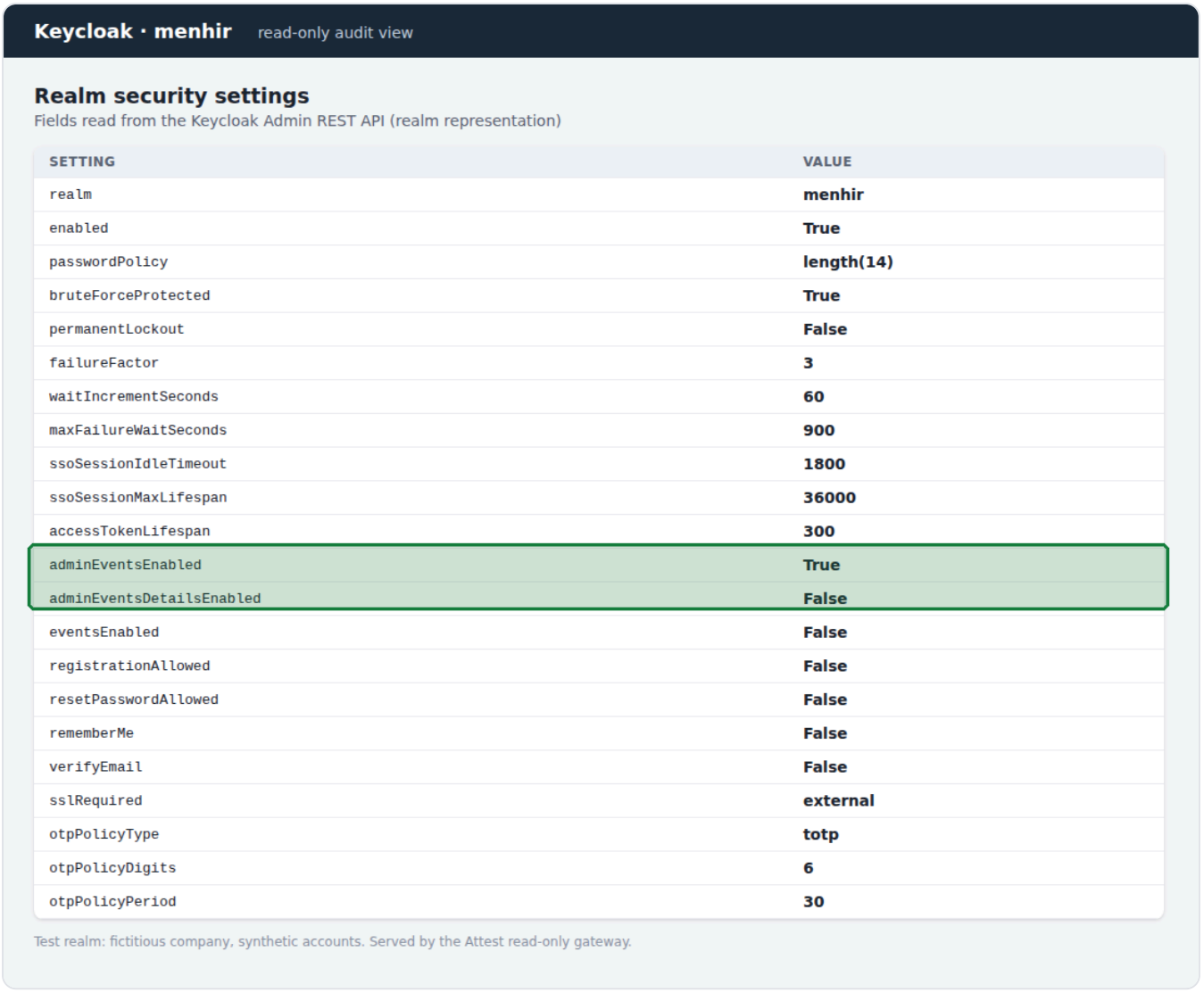



**At testing** — The screenshot corroborates the test. Screenshot shows bruteForceProtected True and failureFactor 3, matching the automated pass result.
`2026-11-11 12:30:38 · SHA-256 e604fb9e82c5006a…`

## PSI-4.6 Logging of administration actions

High · Compliant

Compliant control — All administration actions must be recorded as admin events. · RTS 12(2)(c)(i)
Observed: `true`




**At testing** — The screenshot corroborates the test. Screenshot shows adminEventsEnabled is True matching the expected value.
`2026-11-11 12:30:51 · SHA-256 66e524d4fa59c51a…`

## PSI-4.7 No generic or shared administrator accounts

High Compliant

Compliant control — No account holding the realm role admin may be generic or shared, each admin must have a nominative username of form initiale.nom and a personal email, not a function identifier or shared mailbox. · DORA 9(4)(c), RTS 21(1)(c), RTS 21(1)(e)(ii)
Observed: `["a.bihan", "l.guivarch", "m.pichon", "y.tanguy"]`




**At testing** — The screenshot corroborates the test. The screenshot lists four admin accounts all with initiale.nom usernames and personal emails. · 4/4 sensitive data items masked

`2026-11-11 12:30:58 · SHA-256 0f8a894deb2f04fe…`

# Appendices

## A. Traceability matrix

| REQUIREMENT | RULE | CONTROL | SCRIPT (SHA-256) | RESULT |
|---|---|---|---|---|
| DORA 9(4)(d), RTS 21(1)(f)(ii) | PSI-4.1 | C1 · MFA enforced for privileged administrator accounts | 6b0de4e7e8437e78 · script library (reused) | Non-compliant |
| DORA 9(4)(d), RTS 21(1)(f)(ii) | PSI-4.2 | C2 · MFA enforced for users of critical system | c2e61c28808cef93 · script library (reused) | Non-compliant |
| DORA 9(4)(d) | PSI-4.3 | C3 · Minimum password length and complexity | d0cead329c96459f · script library (reused) | Non-compliant |
| DORA 9(4)(c) | PSI-4.4 | C4 · Account lockout after repeated failures | 8e6c056f9268416a · script library (reused) | Compliant |
| DORA 9(4)(c) | PSI-4.5 | C5 · Inactive session timeout | a1dcf90b1888dffd · script library (reused) | Non-compliant |
| RTS 12(2)(c)(i) | PSI-4.6 | C6 · Logging of administration actions | 033e67f8092e2f55 · script library (reused) | Compliant |
| DORA 9(4)(c), RTS 21(1)(c), RTS 21(1)(e)(ii) | PSI-4.7 | C7 · No generic or shared administrator accounts | ad12cb2ee7e9bb75 · script library (reused) | Compliant |

## B. Evidence register

| FILE | | | SHA-256 |
|---|---|---|---|
| evidence/C1_before.png | C1 · At testing | 2026-11-11 12:30:42 | f7b6246495be512991d0eacc26a7df047f2aeb1b36dc5c56bcf9b0054dbb834a |
| evidence/C2_before.png | C2 · At testing | 2026-11-11 12:31:27 | dad7faedc4d194d7f80c06c452a8e3d1270db1e2961b0105c3be4fe64228f8b3 |
| evidence/C3_before.png | C3 · At testing | 2026-11-11 12:30:37 | 64b8789ad5b89ccbee6b0ed0f6eab8751b5e9c066f1104c37eca24c72d15b0b1 |
| evidence/C4_before.png | C4 · At testing | 2026-11-11 12:30:38 | e604fb9e82c5006a9a5a3c4246ae71ab3afd3999032b09f8260c37fc4dd2342e |
| evidence/C5_before.png | C5 · At testing | 2026-11-11 12:30:51 | b0a6437a5f1517794342f2bb440ab3a3b6e11250f4bd6754ae78bfe79ebef5ff |
| evidence/C6_before.png | C6 · At testing | 2026-11-11 12:30:51 | 66e524d4fa59c51a1592a9edd1250a253fdeac97c908f0b1e0a2d46fc0ec60ac |
| evidence/C7_before.png | C7 · At testing | 2026-11-11 12:30:58 | 0f8a894deb2f04fe9f92c4d7f9d0b7d740b92322e5dd85e393c552df3db1da10 |

## C. AI usage, costs and human oversight

| MODEL | CALLS | INPUT TOKENS | OUTPUT TOKENS | IMAGES | COST (USD) |
|---|---|---|---|---|---|
| muse-spark-1.3 | 7 | 15,254 | 15,462 | 0 | 0.0848 |

| | | | | | |
|---|---|---|---|---|---|
| sam-3.1 | 12 | 0 | 0 | 12 | price not published |
| **Total** | | | | | **0.0848** |

Sensitive data (personal data and secrets) in evidence: 86/88 spotted by Muse Spark + SAM, 88/88 masked in the end thanks to the deterministic safety net (page text).

* sam-3.1: price not published (pricing.toml)

## Safeguards

- Scripts: allow-listed imports, no write requests (static analysis before execution).
- Read-only test account: any write would be refused by the system (defence in depth).
- Fixes: allow-listed route and parameters, human approval, separate change account.
- Segregation of duties: the approver cannot be the auditor.

## D. Integrity

Audit-trail fingerprint when the report was issued. Verify with `python -m attest verify <folder>`.

`f54a0421a27be90d03190353ee6abbed381158ecdff365a50f36d89306c4a166`